If you follow the OAuth2 recommendations in this chapter, then finding out who a user is involves three roundtrips to the AS for the client:

1. First, the client needs to call the authorization endpoint to get an authorization code.
2. Then the client exchanges the code for an access token.
3. Finally, the client can use the access token to call the UserInfo endpoint to retrieve the identity claims for the user.

This is a lot of overhead before you even know the user's name, so OIDC provides a way to return some of the identity and authentication claims about a user as a new type of token known as an *ID token*, which is a signed and optionally encrypted JWT. This token can be returned directly from the token endpoint in step 2, or even directly from the authorization endpoint in step 1, in a variant of the implicit flow. There is also a hybrid flow in which the authorization endpoint returns an ID token directly along with an authorization code that the client can then exchange for an access token.

> **DEFINITION** An ***ID token*** is a signed and optionally encrypted JWT that contains identity and authentication claims about a user.

To validate an ID token, the client should first process the token as a JWT, decrypting it if necessary and verifying the signature. When a client registers with an OIDC provider it specifies the ID token signing and encryption algorithms it wants to use and can supply public keys to be used for